SESSION 04

Bank Branch Security Lab

Phase 4 · Hardening: Group Policy and file access · October 10, 2026

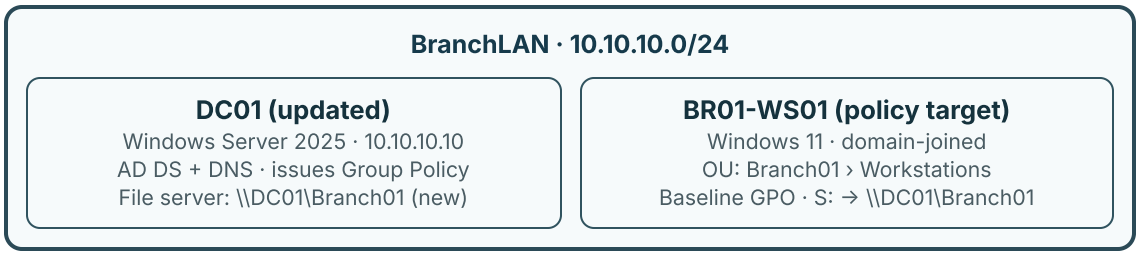
Goal	Turn the branch domain into a governed one: enforce security rules on every workstation through Group Policy, then give staff a shared drive where each role reaches only what its job requires.
Outcome	Domain password and lockout policy enforced, a workstation baseline applied and verified, a test lockout traced to its source in the DC security log, and a role-based file share with access-based enumeration mapped to staff automatically.
Systems built	GPOs Branch01-Workstation-Baseline and Branch01-Drive-Maps · Default Domain Policy updated · SMB share \\DC01\Branch01
Skills	Group Policy, account security policy, security baselines, Windows event log analysis, share and NTFS permissions, least privilege, PowerShell and icacls

Overview

This phase turned the domain into a governed environment. I moved BR01-WS01 into a Branch01 › Workstations OU so policy could target it, set a domain-wide password and lockout policy, and built a workstation baseline GPO that locks idle screens after five minutes, shows a legal logon banner, hides the last signed-in user, and blocks removable storage. I confirmed both GPOs applied with `gpresult`, locked out a test account on purpose, and traced the lockout to its source through Event ID 4740 on DC01. I then built a branch file share, \\DC01\Branch01, with Tellers, Managers, IT and Common folders, least-privilege NTFS permissions per group, access-based enumeration, and a drive mapped for all staff by Group Policy.

Architecture

The topology is unchanged. DC01 now also serves the branch file share and issues Group Policy, and BR01-WS01 receives its security rules and mapped drive from the domain.



Where each policy applies

GPO	Linked to	Sets
Default Domain Policy	jrbankna.internal (root)	Password and account lockout policy for every domain account
Branch01-Workstation-Baseline	Branch01 › Workstations	Auto-lock, logon banner, last user hidden, removable storage blocked
Branch01-Drive-Maps	Branch01 › Staff	S: drive mapped to \\DC01\Branch01

Domain password and lockout policy

Setting	Value	Purpose
Enforce password history	24 remembered	Stops cycling back to an old password
Maximum password age	90 days	Limits how long a stolen password stays useful
Minimum password length	12 characters	Length is the biggest factor in cracking resistance
Complexity requirements	Enabled	Requires a mix of character types
Account lockout threshold	5 invalid attempts	Stops password guessing
Account lockout duration	15 minutes	Auto-unlocks if the help desk isn't reached

Workstation baseline (Branch01-Workstation-Baseline)

Setting	Value
Interactive logon: machine inactivity limit	300 seconds (5 minutes)
Interactive logon: don't display last signed-in	Enabled
Logon message title	JR Bank NA – Authorized Use Only
Logon message text	Authorized employees only; all activity monitored and logged
All Removable Storage classes: Deny all access	Enabled

Branch file share

Share name / path	Branch01 · C:\Shares\Branch01 on DC01 · UNC \\DC01\Branch01
Folders	Tellers · Managers · IT · Common
Share permissions	Domain Admins Full · Domain Users Change (broad on purpose; NTFS does the real control)
Enumeration	Access-based: users only see folders they can open
Drive mapping	S: mapped by GPO for the Staff OU, label "Branch Share"

NTFS access by role

Pick a group, then read down to see every folder it can reach.

Folder	GG-Tellers	GG-Managers	GG-IT	Everyone else
Tellers	Modify	Read	No access	No access
Managers	No access	Modify	No access	No access
IT	No access	No access	Modify	No access
Common	Modify	Modify	Modify	Modify
Branch01 (root)	List only	List only	List only	List only

SYSTEM and Administrators hold Full control everywhere, inherited from the root. Administrative access goes through the separate adm.jryounger account.

What I built

1. Corrected the lab clocks, configuring DC01 as the domain's reliable time source with `w32tm` and resyncing BR01-WS01 to DC01.
2. Created the Branch01 › Workstations OU and moved BR01-WS01 out of the built-in Computers container into it.
3. Edited the Default Domain Policy for the password and lockout settings, then built and linked Branch01-Workstation-Baseline to the Workstations OU.
4. Added the legal logon banner, hid the last signed-in user, and denied all removable storage classes.
5. Ran `gpupdate /force` on BR01-WS01 and confirmed both GPOs applied with `gpresult /r`.
6. Signed in as wade.wilson with five wrong passwords; Event ID 4740 on DC01 showed the account locked out, caller computer BR01-WS01, then unlocked it.
7. Created the Branch01 SMB share with access-based enumeration, removed inherited permissions on the root, and granted role-based NTFS access with `icacls`.
8. Linked Branch01-Drive-Maps to the Staff OU mapping S:, then as wade.wilson confirmed write access to Tellers and that the Managers folder did not exist from his point of view.

Design decisions

Decision	Rationale
Fix time before anything else	Kerberos rejects logins when a client's clock differs from the DC's by more than five minutes. Time is infrastructure, like DNS.
Password policy in Default Domain Policy	Domain account password and lockout rules only take effect from a GPO linked at the domain root.
Lockout at 5 attempts for 15 minutes	Stops guessing attacks while letting a genuine user recover without a call if the help desk is busy.
5-minute inactivity lock	PCI DSS requires re-authentication after at most 15 minutes idle; five minutes suits customer-facing desks without fighting the control.
Block removable storage	USB drives are a top route for data theft and malware into branch PCs.
Broad share permissions, strict NTFS	Two layers where the stricter wins. Managing access in one place (NTFS) avoids conflicting rules.
Permissions granted to groups only	Onboarding and offboarding become group changes; no folder ever names an individual.
Access-based enumeration	Users can't see folders they can't open, which cuts curiosity and reconnaissance.

Verification

Check	How	Result
Workstation in correct OU	`gpresult /r`	Pass · OU=Workstations,OU=Branch01
Both GPOs applied	`gpresult /r` › Applied GPOs	Pass · Baseline + Default Domain
Last user hidden	Sign-in screen	Pass · shows "Other user"
Lockout after 5 failures	Sign in as wade.wilson	Pass · account locked out
Lockout logged on the DC	Event Viewer › Security › 4740	Pass · wade.wilson · caller BR01-WS01
Share created	New-SmbShare output	Pass · C:\Shares\Branch01
Tellers ACL	Tellers › Properties › Security	Pass · Tellers Modify, Managers Read
S: drive mapped	File Explorer as wade.wilson	Pass · S: present
Teller can write to Tellers	New file in Tellers	Pass · cash-drawer-notes.txt
Managers hidden from teller	`dir \\DC01\Branch01\Managers`	Pass · File Not Found

Troubleshooting

Sixth sign-in attempt seemed to show the wrong message

Cause	Windows 11 adds a delay after failed sign-ins to slow guessing; the screen was still in the delay from attempt five.
Fix	Waited for the delay, then saw "the referenced account is currently locked out" and Event 4740. Let the system finish its response before concluding a control failed.

Explorer error 0x80004005 on the Managers path

Cause	Explorer reports blocked share paths with a generic error. Access-based enumeration hides Managers from wade.wilson entirely.
Fix	From Command Prompt, `dir` on Managers returned "File Not Found" while Tellers listed normally: server reachable, own folder writable, Managers invisible, exactly the intended result.